



Configurare gli apparati di rete per snap

Che cosa deve fare il reparto rete perché una sonda veda tutto ciò che c'è, e non solo ciò che risponde. Ogni voce dice che cosa configurare, dove, perché serve e che cosa si perde se non si fa.

15/09/2026 16:07

Che cosa deve fare il reparto rete perché una sonda veda tutto ciò che c'è, e non solo ciò che risponde. Ogni voce dice che cosa configurare, dove, perché serve e che cosa si perde se non si fa.

Riferimenti		Contenuto del documento
Sorgente	18_CONFIGURAZIONE_APPARATI_DI_RE	1. Scopo e come si legge questo documento
Prodotto	snap - Secure Network Assessment Platform	2. Il quadro: dove sta la sonda e con chi parla
		3. Scansione attiva: far sì che gli apparati rispondano
		4. SNMP: il singolo intervento che rende di più
		5. Osservazione passiva: la porta mirror
		6. Log degli apparati verso il SIEM
		7. Agenti di macchina
		8. Dichiarare le reti senza fili
		9. Riepilogo: dal minimo al massimo
		10. Verifica: come sapere che ha funzionato
		11. Che cosa snap non chiede, e perché vale la pena saperlo

Documento generato dal sorgente in docs/: se il contenuto cambia, cambia il sorgente e questo PDF si rigenera. Una copia modificata a mano sarebbe una seconda verità'.

15/09/2026 16:07 · periodo di riferimento: documentazione di prodotto

Sommario

1. Scopo e come si legge questo documento	3
1.1 Come si legge una richiesta	3
2. Il quadro: dove sta la sonda e con chi parla	3
2.1 La direzione delle connessioni	3
2.2 Flussi da consentire	3
2.3 Dove collocare la sonda	3
3. Scansione attiva: far sì che gli apparati rispondano	4
3.1 Non bloccare la sonda	4
3.2 Consentire il traffico di scansione fra VLAN	4
3.3 Porte interrogate	4
3.4 Privilegi della macchina che ospita la sonda	4
4. SNMP: il singolo intervento che rende di più	5
4.1 Perché conta tanto	5
4.2 Che cosa configurare	5
4.3 Gli OID effettivamente letti	5
5. Osservazione passiva: la porta mirror	5
5.1 Che cosa si vede senza mirror	5
5.2 Che cosa configurare	5
5.3 Due avvertenze operative	6
6. Log degli apparati verso il SIEM	6
7. Agenti di macchina	6
8. Dichiarare le reti senza fili	6
9. Riepilogo: dal minimo al massimo	6
10. Verifica: come sapere che ha funzionato	7
11. Che cosa snap non chiede, e perché vale la pena saperlo	7

DOCUMENTO	PREREQUISITI E CONFIGURAZIONE DEGLI APPARATI DI RETE
Destinatari	Amministratori di rete e sistemisti del cliente
Versione documentata	console 2.0.8, sonda 1.5.0, agente 1.2.6
Conformità	ISO/IEC/IEEE 29148:2018 (§1 scopo, §2 riferimenti, §5 requisiti), NIS2 art. 21(2)(a,e,g)
Aggiornato	2026-09-15

1. Scopo e come si legge questo documento

snap raccoglie da una rete aziendale tre cose diverse, con tre meccanismi diversi: che cosa esiste (scansione attiva), che cosa succede (osservazione passiva e log), che cosa c'è dentro una macchina (agente facoltativo). Ciascuno ha prerequisiti propri sugli apparati di rete.

Niente di quanto segue è obbligatorio. Il prodotto funziona anche su una rete in cui non si tocca nulla: raccoglie meno, e dichiara ciò che non ha potuto vedere invece di lasciarlo intendere. Questo documento serve a decidere quanto si vuole vedere e a pagare il prezzo corrispondente in configurazione.

Ogni sezione è ordinata per rapporto fra guadagno e fatica. Se si ha tempo per una cosa sola, si faccia la §3. Se per due, la §3 e la §5.

1.1 Come si legge una richiesta

Ogni voce ha la stessa forma:

CAMPO	SIGNIFICATO
Cosa	la configurazione da applicare
Dove	su quale apparato
Perché	che cosa abilita nel prodotto
Se non si fa	che cosa si perde, in concreto

2. Il quadro: dove sta la sonda e con chi parla

2.1 La direzione delle connessioni

Questa è la regola che governa tutto il resto e va capita prima di aprire qualunque porta sul firewall:

agente di macchina → sonda → server snap

Le frecce vanno in una sola direzione. Il server non apre mai una connessione verso una sonda; la sonda non apre mai una connessione verso un agente. Chi sta più all'interno chiama chi sta più all'esterno, mai il contrario.

Conseguenza pratica per il firewall: non serve alcuna regola in ingresso verso la rete del cliente, né alcun NAT statico, né alcuna VPN in entrata. Se qualcuno vi chiede di pubblicare una sonda su Internet, sta chiedendo una cosa che il prodotto non usa.

2.2 Flussi da consentire

DA	A	PORTA	PROTOCOLLO	NOTE
Sonda	Server snap	443/TCP	HTTPS	in uscita; è l'unico flusso verso l'esterno
Agente di macchina	Sonda	5510/TCP	HTTPS	solo se si usano gli agenti (§7)
Apparati di rete	Server snap	514 e/o 5514 UDP+TCP	syslog	solo se si usa il SIEM (§6)
Sonda	Rete da censire	varie	vedi §3.2	traffico di scansione

La sonda contatta il server ogni 15 secondi. Se il collegamento cade, accumula localmente e riprende quando torna: non serve alcuna garanzia di continuità sul collegamento.

2.3 Dove collocare la sonda

Cosa — collocare la sonda in una VLAN che abbia instradamento verso tutte le subnet da censire, e preferibilmente su una porta di switch in un punto di concentrazione del traffico.

Perché — la sonda è un host come gli altri: raggiunge ciò che la tabella di instradamento le permette di raggiungere.

Se non si fa — le subnet non raggiungibili semplicemente non vengono censite. Compaiono nel perimetro come «mai censite», il che è corretto ma inutile.

Se le subnet sono molte e separate da firewall interni, è preferibile più sonde che una sola sonda con molti permessi. Una sonda per zona di sicurezza è l'architettura che il prodotto si aspetta, ed è anche quella che un revisore accetta senza discutere.

3. Scansione attiva: far sì che gli apparati rispondano

È la fonte principale dell'inventario. Costa poca configurazione e rende molto.

3.1 Non bloccare la sonda

Cosa — inserire l'indirizzo della sonda in una lista di esclusione su:

- IPS/IDS perimetrali e interni;
- protezione dagli scan sugli switch (port security, storm control, DHCP snooping con limitazione ARP);
- antivirus/EDR delle postazioni, per la parte «rilevamento scansioni di rete»;
- firewall interni fra VLAN.

Dove — su ogni apparato che applica contromisure automatiche.

Perché — una scansione ordinata assomiglia, per forma, a una ricognizione ostile. È normale che i sistemi di difesa la segnalino; il problema è quando la bloccano, perché allora l'inventario diventa silenziosamente incompleto.

Se non si fa — gli apparati protetti risultano «non raggiungibili» o mostrano molte meno porte del vero. Il danno peggiore non è l'assenza del dato: è che il dato sbagliato sembra un dato.

Questa esclusione va documentata nel registro delle configurazioni: è un'eccezione a una misura di sicurezza, e come tale va motivata e rivista periodicamente (NIS2 art. 21(2)(a)).

3.2 Consentire il traffico di scansione fra VLAN

Cosa — dalla VLAN della sonda verso le subnet da censire, consentire:

TRAFFICO	PERCHÉ SERVE
ICMP echo (tipo 8) e risposta	individuazione degli host attivi
TCP SYN verso le porte in §3.3	riconoscimento dei servizi
UDP 161, 137, 5353, 1900, 123, 67, 47808	identificazione di apparati che non aprono porte TCP (SNMP, NetBIOS, mDNS, UPnP, NTP, DHCP, BACnet)

Se non si fa — senza ICMP molti host risultano assenti anche se ci sono; senza le porte UDP, stampanti, telecamere, apparati di automazione e telefoni restano indistinguibili l'uno dall'altro.

3.3 Porte interrogate

Per il riconoscimento rapido la sonda interroga un elenco breve e stabile:

21 22 23 25 53 80 110 111 135 139 143 443 445 515 631 1025 1433 1521
3306 3389 5060 5357 5432 5900 7070 8080 8443 9100 5555 62078

Le ultime due meritano una nota: 62078 è il servizio di sincronizzazione di iOS e 5555 il ponte di debug Android. Sono le uniche porte che un telefono offra: senza di esse un dispositivo mobile non ha alcun segnale ed è riconoscibile solo dal costruttore della scheda di rete — dato che su una subnet instradata non si ha (vedi §5.1).

Sugli host che hanno mostrato un segnale viene poi eseguita una passata di approfondimento su circa 230 porte scelte per famiglia di apparato.

3.4 Privilegi della macchina che ospita la sonda

Cosa — eseguire la sonda con privilegi amministrativi (root, oppure Amministratore su Windows con Npcap installato).

Perché — senza privilegi elevati nmap non può usare la scansione SYN (-sS) né il riconoscimento del sistema operativo (-O) e ripiega sulla scansione per connessione: più lenta, più rumorosa nei log degli apparati, e senza sistema operativo.

Se non si fa — l'inventario perde il campo «sistema operativo» su tutti gli apparati che non lo dichiarano in altro modo, e con esso la correlazione con le vulnerabilità note e il calcolo del fine supporto.

La sonda dichiara nella propria pagina di stato se sta lavorando senza privilegi: non è una condizione da indovinare.

4. SNMP: il singolo intervento che rende di più

Se si può fare una cosa sola, è questa.

4.1 Perché conta tanto

Un apparato di rete conosce cose che nessuna scansione può dedurre da fuori:

- la propria tabella ARP, cioè la corrispondenza indirizzo IP > indirizzo MAC per ogni rete a lui attestata;
- la propria tabella di inoltro, cioè su quale porta fisica si trova un dato MAC.

Con queste due, l'inventario passa da «c'è un apparato a questo indirizzo» a «c'è questo apparato, di questo costruttore, attaccato a questa porta di questo switch».

4.2 Che cosa configurare

Cosa — abilitare SNMP v2c in sola lettura (o v3 con autenticazione) su switch, router e firewall, con una community dedicata e una ACL che ne consenta l'uso al solo indirizzo della sonda.

Dove — su ogni switch di distribuzione e accesso, e su ogni router/firewall che faccia da gateway per una subnet censita.

Perché — sono le due tabelle della §4.1.

Se non si fa — resta l'inventario per indirizzo IP, senza MAC e senza posizione fisica. Sulle subnet instradate il MAC non si può ottenere in nessun altro modo: ARP non attraversa un router.

4.3 Gli OID effettivamente letti

Chi deve autorizzare una vista SNMP ristretta può limitarla a questi rami:

DATO	OID
Descrizione del sistema	1.3.6.1.2.1.1.1
Nome del sistema	1.3.6.1.2.1.1.5
Tabella ARP	1.3.6.1.2.1.4.22.1.2
Inoltro bridge (dot1d)	1.3.6.1.2.1.17.4.3.1.2
Inoltro bridge per VLAN (dot1q)	1.3.6.1.2.1.17.7.1.2.2.1.2
Porta bridge > ifIndex	1.3.6.1.2.1.17.1.4.1.2
Nome dell'interfaccia	1.3.6.1.2.1.31.1.1.1.1
Descrizione dell'interfaccia	1.3.6.1.2.1.2.2.1.2

Nessun OID di scrittura, in nessun caso. Se la vista concede solo questi rami, il peggio che possa fare una credenziale compromessa è leggere la topologia — che è comunque un dato sensibile, ma non permette di modificare nulla.

Su molti switch le tabelle di inoltro sono per VLAN e richiedono l'indicizzazione di contesto (SNMP v2c: community@VLAN; v3: contesto esplicito). Se l'apparato la richiede e non la si configura, la tabella ARP arriva e quella di inoltro no: si ottiene il MAC ma non la porta.

5. Osservazione passiva: la porta mirror

5.1 Che cosa si vede senza mirror

Anche senza alcuna configurazione, alla sonda arriva tutto il traffico broadcast del proprio segmento. Sembra poco ed è invece dove vivono gli attacchi di segmento: ARP, DHCP, LLMNR/NBNS. Su una rete reale venti secondi bastano a vedere le schede di rete di tutto il segmento, comprese quelle che a una scansione non rispondono.

Quello che non si vede senza mirror sono le conversazioni fra altri: scansioni interne, comunicazioni periodiche verso l'esterno, nomi richiesti da altre postazioni.

5.2 Che cosa configurare

Cosa — configurare una porta mirror (SPAN) che copi verso la porta della sonda il traffico di interesse. In ordine di utilità:

1. il collegamento fra lo switch di distribuzione e il firewall/router perimetrale;
2. le VLAN degli utenti;

- 3. le VLAN dei server.

Dove — sullo switch di distribuzione principale.

Perché — abilita il riconoscimento di comunicazioni periodiche verso l'esterno, scansioni interne, avvelenamento dei nomi e tunnel DNS.

Se non si fa — le regole corrispondenti restano dichiarate ma inattive. Il prodotto lo scrive nella pagina dei sensori: una regola che non può scattare non deve sembrare una regola che non ha trovato niente.

5.3 Due avvertenze operative

- Dimensionare il mirror. Copiare un collegamento a 10 Gb/s su una porta a 1 Gb/s fa scartare pacchetti in silenzio. La sonda conta i pacchetti scartati e li mostra: se quel numero cresce, il mirror è sovradimensionato rispetto alla porta.
- L'osservazione riguarda le persone. Il traffico osservato è quello di chi lavora su quella rete. snap legge solo intestazioni e nomi in chiaro, mai il contenuto, conserva i pacchetti per pochi minuti e non li trasmette mai al server. Va comunque coordinato con il titolare del trattamento e, dove previsto, con le rappresentanze sindacali (art. 4 St. Lav.; GDPR artt. 5, 6, 13).

6. Log degli apparati verso il SIEM

Cosa — configurare l'invio syslog dagli apparati verso il server snap, porta 514/UDP (standard) oppure 5514/UDP e TCP.

Dove — firewall, switch, controller wireless, server di autenticazione, reverse proxy.

Perché — è l'unica fonte che dice chi ha fatto che cosa e quando su un apparato di rete. La scansione dice com'è configurato; il log dice come è stato usato.

Se non si fa — restano l'inventario e lo stato, senza la storia. Per la notifica degli incidenti prevista da NIS2 (art. 23) la storia è ciò che serve.

Priorità suggerita, se non si possono configurare tutti:

- 1. firewall perimetrale (connessioni bloccate e consentite);
- 2. server di autenticazione (accessi riusciti e falliti);
- 3. controller wireless (associazioni);
- 4. switch (cambi di configurazione, porte su e giù).

7. Agenti di macchina

L'agente è facoltativo e vede ciò che dalla rete non si vede: processi in ascolto con il loro utente, patch installate, utenze locali e amministratori, stato delle protezioni.

Cosa — consentire il traffico dalle postazioni/server verso la sonda sulla porta 5510/TCP, e distribuire l'agente con gli strumenti che già si usano (GPO, MDM, Ansible).

Perché — è l'unico modo di sapere se una porta aperta appartiene a un servizio legittimo, e di correlare una vulnerabilità con la patch che la chiude.

Se non si fa — l'inventario resta quello visto da fuori. Non è un inventario sbagliato, è un inventario meno profondo.

L'agente non apre porte in ascolto sulla macchina: chiama lui la sonda. Nessuna regola firewall in ingresso verso le postazioni.

8. Dichiarare le reti senza fili

Cosa — nel perimetro di scansione di snap, marcare come «senza fili» le subnet servite da Wi-Fi.

Dove — nella console, non sugli apparati.

Perché — su una rete senza fili il DHCP riassegna di continuo: un indirizzo non è un apparato. Le subnet così marcate ricevono due trattamenti propri: una ricognizione delle presenze ogni due minuti (chi c'è adesso) e una scoperta ogni sei ore invece di tre giorni delle reti cablate (che cosa c'è).

Se non si fa — le reti Wi-Fi vengono censite con la cadenza delle reti cablate, e l'elenco risultante fotografa un momento spacciandolo per lo stato.

9. Riepilogo: dal minimo al massimo

LIVELLO	CHE COSA SI CONFIGURA	CHE COSA SI OTTIENE IN PIÙ
0 — niente	—	inventario per indirizzo IP, stato dei servizi, rilevazioni di segmento

LIVELLO	CHE COSA SI CONFIGURA	CHE COSA SI OTTIENE IN PIÙ
1 – minimo	esclusione della sonda dalle contromisure (§3.1), instradamento e porte (§3.2), privilegi (§3.4)	inventario completo e affidabile, sistema operativo, fine supporto
2 – consigliato	SNMP in sola lettura (§4)	MAC, costruttore, posizione fisica sulle porte degli switch
3 – completo	porta mirror (§5), syslog (§6)	riconoscimento delle intrusioni sul traffico, storia degli eventi
4 – massimo	agenti di macchina (§7)	processi, patch, utenze, postura di sicurezza interna

Il salto che rende di più, a parità di fatica, è da 1 a 2.

10. Verifica: come sapere che ha funzionato

Dopo ogni intervento, la verifica si fa nella console, non sull'apparato:

INTERVENTO	DOVE SI VERIFICA	CHE COSA SI DEVE VEDERE
§3.1 esclusione	Sala operativa > Quadro NOC	gli apparati esclusi non risultano più «non raggiungibili»
§3.4 privilegi	Sonda > Stato	scompare l'avviso sui privilegi; compare il sistema operativo sui nodi
§4 SNMP	Rete > Nodi, filtro «MAC riferito da un apparato»	i nodi delle subnet instradate acquistano il MAC
§5 mirror	Sonda > IDS, elenco dei sensori	le regole sul traffico passano da «non può scattare» ad attive
§6 syslog	SIEM > Sorgenti	l'apparato compare fra le sorgenti, con l'ora dell'ultimo messaggio
§7 agenti	Sonda > Agenti	la macchina compare con l'ora dell'ultimo invio

Se dopo un intervento il valore atteso non compare entro un giro di scansione (al massimo tre giorni per il censimento completo, sei ore per le reti senza fili), la configurazione non ha avuto effetto: non è un ritardo del prodotto.

11. Che cosa snap non chiede, e perché vale la pena saperlo

Per chiudere una valutazione di sicurezza, queste sono le cose che non servono:

- nessuna regola firewall in ingresso verso la rete del cliente;
- nessun NAT statico, nessuna VPN in entrata, nessuna pubblicazione su Internet;
- nessuna credenziale SNMP di scrittura;
- nessuna credenziale di dominio, nessun account privilegiato sulle postazioni;
- nessun agente in ascolto su una porta;
- nessun accesso al contenuto del traffico.

Se una richiesta che ricevete non è in questo documento e contraddice questo elenco, verificatela prima di applicarla.